

TheThirdEye / AegisMail — Comprehensive Project Specification & Technical Documentation

Smart India Hackathon (SIH 2026)

Project Name: AegisMail / TheThirdEye

Category: Cybersecurity & AI-Driven Automated Threat Intelligence

Repository: <https://github.com/Savya211/SIH-26>

Table of Contents

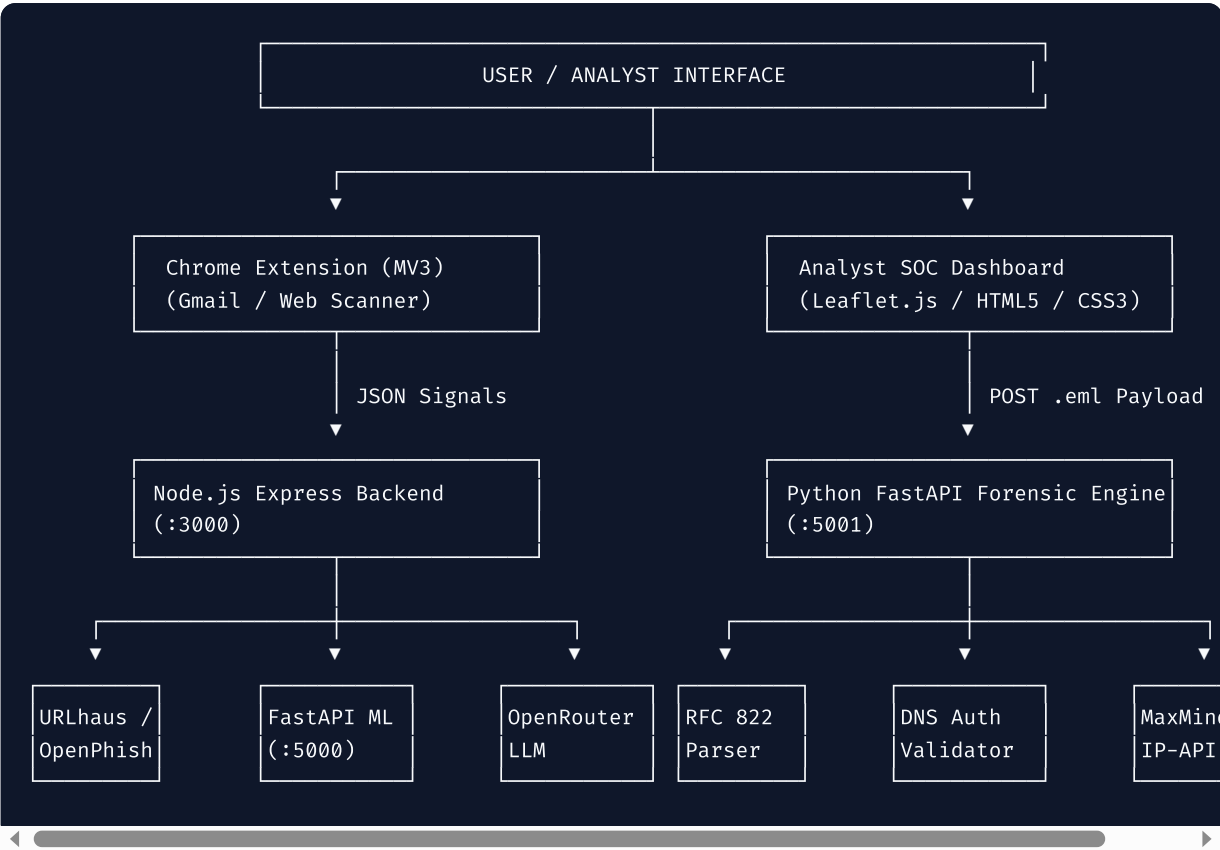
1. [Executive Summary](#)
 2. [Complete System Architecture](#)
 3. [Comprehensive Feature Matrix](#)
 4. [Languages, Frameworks & Libraries](#)
 5. [Complete API Catalog & Specifications](#)
 6. [Internal Microservice APIs](#)
 7. [External Third-Party APIs & Services](#)
 8. [Forensic Risk Engine & Scoring Algorithm](#)
 9. [Repository File Inventory](#)
 10. [Setup, Execution & Deployment Guide](#)
-

1. Executive Summary

TheThirdEye / AegisMail is an end-to-end cybersecurity ecosystem built to solve two major modern digital attack vectors: 1. **Advanced Email Phishing & BEC (Business Email Compromise)** — Investigated via an automated AI-powered Python Forensic Engine and SOC Analyst Web Dashboard. 2. **Real-time Web Threats & Privacy Invasion** — Protected via a Chrome Manifest V3 Browser Extension providing inline DOM defense, password breach shields, and zero-overhead tracker blocking.

The system ingests raw `.eml` email files or live browser signals, evaluates multi-dimensional risk factors across 4 defense layers, maps physical server hops on a dark CartoDB GIS map, and delivers instant threat verdicts with transparent indicators.

2. Complete System Architecture



3. Comprehensive Feature Matrix

 A. Email Forensic Engine & Intelligence Platform (forensic-engine/)

- **Multi-Stage RFC 822 Header Parsing:** Extracts sender details (From , Return-Path , Reply-To), authentication tags, message IDs, timestamp chains, and full server relay history (Received: headers).
- **Live DNS Email Authentication:**
- **SPF (Sender Policy Framework):** Fetches domain TXT records to verify sender IP authorization.
- **DMARC (Domain-based Message Authentication):** Checks policy enforcement (p=reject , p=quarantine , p=none).
- **Domain Mismatch Alignment:** Detects From vs. Reply-To and Return-Path domain spoofing attempts.
- **NLP & Threat Content Analyzer:**
- **Urgency & Psychological Lure Detection:** Scans for pressure phrases ("Account Suspended", "Action Required within 24 hours", "Unauthorized Login Detected").
- **Financial & Credential Harvesting Phrases:** Identifies BEC wire transfer requests, cryptocurrency wallet traps, and login verification lures.
- **Suspicious Tunnel & Infrastructure Domains:** Detects links hiding behind ngrok , serveo , loclX , trycloudflare , localxpose .
- **Double Extension Attachment Guard:** Flags dangerous files disguised as documents (e.g., invoice.pdf.exe , statement.doc.js).

- **Hop-by-Hop GeoTrace Engine:**
 - Extracts public IPv4/IPv6 addresses along the email path.
 - Queries GeolIP locations (City, Country, Latitude, Longitude, Autonomous System Number / ASN).
 - Calculates physical hop trajectory across continents.
 - **Persistent Forensic Case Management:**
 - Generates unique SHA-256 case IDs (`CASE-xxxx`).
 - Stores structured JSON forensic reports in `forensic-engine/data/cases/` .
-

B. Analyst Investigation Dashboard (`analyst-dashboard/`)

- **Leaflet.js Dark GeoTrace World Map:** Renders origin, intermediate relays, and destination nodes using dark CartoDB tiles with animated polylines and pulse indicators.
 - **Animated Composite Risk Dial:** SVG-rendered threat gauge updating from `0` to `100` with dynamic verdict styling:
 -  **CRITICAL PHISHING** (80 - 100)
 -  **HIGH RISK** (60 - 79)
 -  **SUSPICIOUS** (30 - 59)
 -  **SAFE** (0 - 29)
 - **Sub-Score Breakdown Panels:**
 - **Authentication Score** (SPF / DMARC / Domain Alignment)
 - **Urgency & Manipulation Score** (Psychological keywords)
 - **URL & Attachment Safety Score** (Suspicious TLDs, IP links, tunnels)
 - **Header Integrity Score** (Missing Message-IDs, date anomalies)
 - **Interactive Raw Header Inspector:** Includes syntax highlighting to inspect original email headers line-by-line.
 - **Preset One-Click Demo Payloads:**
 -  `Spoofed Bank Alert` (Impersonating Chase Bank)
 -  `Executive BEC Wire Transfer` (CEO urgent request)
 -  `Clean Corporate Newsletter` (Legitimate newsletter)
-

C. Chrome Browser Extension (`manifest.json` — Manifest V3)

- **Inline Gmail Threat Scanner:** Injects safety badges directly into Gmail email headers and scans embedded email URLs.
- **Homoglyph & IDN Lookalike Domain Detector:** Detects internationalized Cyrillic/Greek character substitution attacks (e.g. `google.com` vs `google.com`).
- **Password Breach Shield (HIBP Integration):** Checks typed passwords against 10B+ breached records using SHA-1 **k-Anonymity** (only first 5 hash characters sent).
- **Zero-Overhead Tracker Blocker:** Uses Manifest V3 `declarativeNetRequest` rules to block telemetry, analytics, and advertising scripts without slowing down page load times.
- **Google Search Safety Annotator:** Injects green/red safety indicators next to Google search results before the user clicks.
- **WebRTC Leak Shield:** Prevents private IP address exposure via WebRTC UDP candidates.

- **Security Headers Grader**: Analyzes site HTTP headers (`CSP` , `HSTS` , `X-Frame-Options` , `X-Content-Type-Options`) and awards grades from **A+** to **F**.

4. Languages, Frameworks & Libraries

Programming Languages

Language	Version / Specification	Usage Area
Python	Python 3.10+	Forensic Engine, RFC 822 Parser, GeoTrace, FastAPI Microservice
JavaScript (ES6+)	Modern Vanilla JS	Chrome Extension (Service Worker, Content Scripts, Popup), Analyst Dashboard UI
HTML5	Semantic HTML5	Dashboard Interface, Extension Popup, Warning Pages
CSS3	Vanilla CSS (Variables, Grid, Flexbox)	Dark-mode Cyberpunk UI design system, Glassmorphism cards

Key Libraries & Frameworks

Python Stack (`forensic-engine/requirements.txt` & `eai/requirements.txt`)

- **FastAPI** : High-performance asynchronous REST API web framework.
- **uvicorn** : Lightning-fast ASGI server implementation.
- **dnspython** : Performs DNS resolution for SPF, DKIM, and DMARC TXT records.
- **beautifulsoup4** : Parses HTML email content and extracts raw links, anchors, and forms.
- **tldextract** : Accurately separates registered domains, subdomains, and TLDs.
- **requests** : HTTP requests for IP geolocation services.
- **scikit-learn** : RandomForest & LogisticRegression ML model training on 235k URLs.
- **geoip2** / **maxminddb** : Local offline database lookup for IP cities and ASNs.

Frontend & Extension Stack

- **Leaflet.js** : Interactive GIS map rendering engine.
- **CartoDB Dark Matter** : Dark basemap tile provider.
- **Chrome Extension API (V3)** : `declarativeNetRequest` , `activeTab` , `storage` , `webRequest` , `cookies` , `scripting` .

5. Complete API Catalog & Specifications

Internal Microservice APIs

1. Analyze Uploaded Email Payload

- **Endpoint:** `POST /api/analyze`
- **Content-Type:** `multipart/form-data`
- **Request Body:** `file: <.eml binary>`
- **Response:**

```
{
  "status": "success",
  "filename": "spoofed_bank.eml",
  "processing_time_seconds": 0.42,
  "case_id": "CASE-a618f9237cf9-1788777798",
  "timestamp": "2026-09-07T10:43:18Z",
  "risk": {
    "threat_score": 92.5,
    "verdict": "CRITICAL PHISHING",
    "sub_scores": {
      "authentication": 100,
      "urgency": 100,
      "link_safety": 75,
      "header_integrity": 95
    },
    "indicators": [
      "DMARC validation failed (policy=reject)",
      "SPF validation failed for sender IP 185.220.101.5",
      "Sender domain (chase-security-update.com) does not match Reply-To (support@chase.com)",
      "High psychological urgency detected (Urgency Score: 100%)",
      "Credential harvesting keyword detected in body"
    ]
  },
  "header_analysis": {
    "from": "Chase Security <alert@chase-security-update.com>",
    "return_path": "bounce@chase-security-update.com",
    "reply_to": "support@chase.com",
    "subject": "URGENT: Your Chase Account Has Been Suspended",
    "date": "Mon, 07 Sep 2026 10:12:00 +0000",
    "message_id": "<202609071012.83921@chase-security-update.com>"
  },
  "hops": [
    {
      "hop_number": 1,
      "by_host": "mail.chase-security-update.com",
      "ip": "185.220.101.5",
      "country": "Germany",
      "city": "Frankfurt",
      "lat": 50.1109,
      "lon": 8.6821,
      "asn": "AS200384",
      "isp": "Tor Exit Node Provider"
    }
  ]
}
```

2. Analyze Demo Email Payload

- **Endpoint:** POST /api/analyze-demo/{filename}
- **Parameters:** filename (spoofed_bank.eml , ceo_wire_transfer.eml , clean_newsletter.eml)

3. Forensic Case Management Endpoints

- GET /api/cases : Returns a list of all stored forensic investigation cases.
- GET /api/cases/{case_id} : Fetches full details for a specific case file.

- `GET /health` : Healthcheck endpoint returning engine status, uptime, and database metrics.

External Third-Party APIs & Services

Service Name	API Endpoint / Resource	Purpose	Auth Required
IP-API Geolocation	<code>http://ip-api.com/json/{ip}</code>	Retrieves IP City, Country, Lat/Lon, and ASN	No
CARTO Basemaps	<code>https://{s}.basemaps.cartocdn.com/dark_all/ ...</code>	Dark GIS tile provider for Leaflet GeoTrace map	Optional (Key parameter supported)
Have I Been Pwned	<code>https://api.pwnedpasswords.com/range/{hash5}</code>	Checks password breaches via k-Anonymity	No
Google Safe Browsing	<code>https://safebrowsing.googleapis.com/v4/threatMatches:find</code>	Queries Google's known malicious web page database	Yes (API Key)
PhishTank API	<code>https://checkurl.phishtank.com/checkurl/</code>	Queries PhishTank phishing link database	Yes (API Key)
URLhaus Feed	<code>https://urlhaus-api.abuse.ch/v1/url/</code>	Community threat feed for malware links	No
OpenRouter AI	<code>https://openrouter.ai/api/v1/chat/completions</code>	LLM fallback for zero-day phishing analysis	Yes (API Key)

6. Forensic Risk Engine & Scoring Algorithm

The threat score S_{threat} in $[0, 100]$ is computed using a weighted composite model across 4 security pillars:

$$S_{\text{threat}} = \min\left(100, \sum_{i=1}^4 w_i \cdot S_i + \delta_{\text{penalty}}\right)$$

Where:

- S_1 = **Authentication Deficit Score** ($w_1 = 0.35$): Computed from SPF failures, DMARC policy violations, and From / Reply-To domain mismatch.
- S_2 = **Psychological Manipulation & Urgency Score** ($w_2 = 0.25$): NLP frequency analysis of high-pressure threat keywords.
- S_3 = **URL & Domain Infrastructure Risk** ($w_3 = 0.25$): Evaluates direct IP links, tunnel domain presence (ngrok , serveo), newly registered domain TLDs, and double extension attachments.
- S_4 = **Header Anomalies Score** ($w_4 = 0.15$): Missing RFC Message-IDs, invalid date formats, or suspicious relay hop count (> 8 hops).
- δ_{penalty} : Flat $+20$ penalty if SPF **AND** DMARC both fail simultaneously.

7. Repository File Inventory

```

TheThirdEye/
├── PROJECT_DOCUMENTATION.md # Master Project Specification (This File)
├── README.md # Quickstart Guide & GitHub Presentation
├── manifest.json # Chrome Extension Manifest V3 Config
├── analyst-dashboard/ # SOC Analyst Forensic Dashboard
│   ├── index.html # Main HTML5 Interface
│   ├── style.css # Dark Cyberpunk CSS Design Tokens
│   ├── app.js # Frontend Controller & API Integration
│   └── map.js # Leaflet.js Map & Polyline Animator
├── forensic-engine/ # Python FastAPI Forensic Engine
│   ├── main.py # FastAPI Application Server Entrypoint
│   ├── requirements.txt # Python Dependencies List
│   ├── create_test_emails.py # Script to generate sample .eml payloads
│   ├── parsers/ # Email Parsing Modules
│   │   ├── __init__.py
│   │   ├── header_parser.py # RFC 822 Header & Relay Extractor
│   │   ├── body_parser.py # HTML Link, Attachment & Text Extractor
│   │   └── auth_validator.py # Live SPF/DMARC DNS Validator
│   ├── analyzers/ # Threat Scoring & Geolocation Engines
│   │   ├── __init__.py
│   │   ├── nlp_engine.py # Psychological Urgency & BEC Classifier
│   │   ├── url_analyzer.py # Link Safety & Tunnel Domain Detector
│   │   ├── geo_tracer.py # IP Geolocation & ASN Lookup Module
│   │   └── risk_scorer.py # Composite Threat Scoring Matrix
│   ├── data/ # MaxMind Databases & Stored Forensic Cases
│   └── test_emails/ # Sample .eml Threat Payloads
├── background/ # Chrome Extension Service Worker
│   └── service-worker.js # Background Threat Orchestrator
├── content/ # Extension Content Scripts
│   ├── gmail-scanner.js # Gmail DOM Link & Header Scanner
│   ├── page-analyzer.js # Webpage Signal Extractor (23+ features)
│   ├── homoglyph-detector.js # IDN Cyrillic/Greek Lookalike Detector
│   ├── password-monitor.js # HIBP k-Anonymity Password Monitor
│   ├── search-scanner.js # Google Search Result Annotator
│   └── mixed-content-detector.js # Insecure HTTP Content Inspector
├── popup/ # Extension UI Interface
│   ├── popup.html # 7-Tab Extension Popup View
│   ├── popup.css # Popup Stylesheet
│   └── popup.js # Popup Controller Script
├── backend/ # Legacy Node.js Express Backend (:3000)
│   ├── server.js # Express Server
│   ├── routes/ # Threat Reputation & Scanner Routes
│   └── services/ # OpenRouter LLM Bridge & Feed Parsers
├── eai/ # Legacy Python ML Microservice (:5000)
│   ├── train.py # RandomForest Model Trainer (PhiUSIIL dataset)
│   ├── serve.py # ML Prediction FastAPI Server
│   └── evaluate.py # Accuracy & ROC-AUC Metric Evaluator

```

```
└─ rules/                                # Tracker Blocking Rules
   └─ tracker-rules.json                 # DeclarativeNetRequest Rule Definitions
```

8. Setup, Execution & Deployment Guide

1. Launch the Forensic Engine (Backend)

```
cd "c:\Users\DELL\OneDrive\Desktop\SIH'26\TheThirdEye\forensic-engine"
pip install -r requirements.txt
python main.py
```

- **Engine Endpoint:** `http://localhost:5001`
- **Swagger API Docs:** `http://localhost:5001/docs`

2. Launch the Analyst Dashboard (Frontend)

```
cd "c:\Users\DELL\OneDrive\Desktop\SIH'26\TheThirdEye\analyst-dashboard"
python -m http.server 8080
```

- Access the dashboard at <http://localhost:8080>.

3. Load the Browser Extension

1. Open Chrome or Edge and go to `chrome://extensions/` .
2. Enable **Developer Mode**.
3. Click **Load Unpacked** and choose `c:\Users\DELL\OneDrive\Desktop\SIH'26\TheThirdEye` .

Documentation maintained for Smart India Hackathon 2026.